



BYOD -1

Static Application Security Testing (SAST) using SonarQube and SonarCloud

Submitted by – Khosbayar Baatarsaikhan

Reg.no – 12222747

Submitted to – Mr. Utkarsh Agarwal

Feb ,16th, 2026

INTRODUCTION

Static Application Security Testing (SAST) is a security testing methodology that analyses source code without executing the application. It helps detect security vulnerabilities, bugs, and code quality issues early in the development lifecycle.

In this assignment, two SAST approaches were implemented:

- Local on-premise analysis using SonarQube
- Cloud-based analysis using SonarCloud

The objective was to configure both environments, analyse the same application, interpret Quality Gate results, and achieve a minimum Quality Gate score of 80%.

Virtual Machine Configuration

A Linux-based virtual machine was created to deploy SonarQube locally. The VM was configured with Ubuntu 22.04 LTS operating system, 4 GB RAM, 2 CPU cores, and 20 GB storage.

OpenJDK 17 was installed to ensure compatibility with SonarQube requirements. The system resources were verified before starting the SonarQube service to ensure stable performance.

SonarQube Installation and Execution

SonarQube was downloaded and extracted on the virtual machine. The service was started using the Linux startup script and accessed through the web browser using:

`http://localhost:9000`

After logging in with administrator credentials, a new project was created for static analysis.

The Sonar Scanner was configured using a `sonar-project.properties` file and executed from the project directory. The analysis results were successfully uploaded to the local SonarQube server dashboard.

Local Quality Gate Interpretation

During analysis, SonarQube evaluated the project based on:

- Bugs
- Vulnerabilities

- Code Smells
- Maintainability Rating
- Security Rating
- Code Coverage

Identified issues were reviewed and resolved to meet the defined Quality Gate threshold of 80%. After remediation, the project successfully passed the Quality Gate.

Virtual Machine setup and readines

[illegible]

Part 1: Local SAST Analysis using SonarQube on VM

SonarCloud Setup and Integration

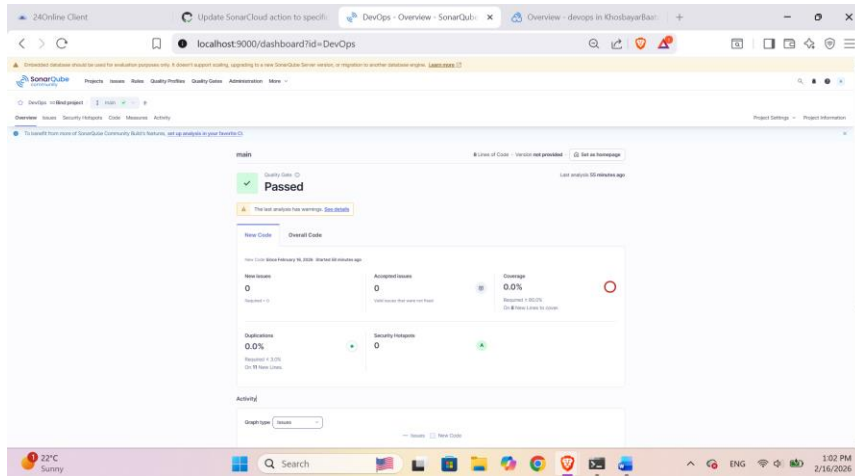
A project was created on SonarCloud and linked with the GitHub repository. Continuous Integration was configured using GitHub Actions to automatically trigger static analysis on every push to the main branch.

The same application used in the local analysis was pushed to the repository to maintain consistency between both environments.

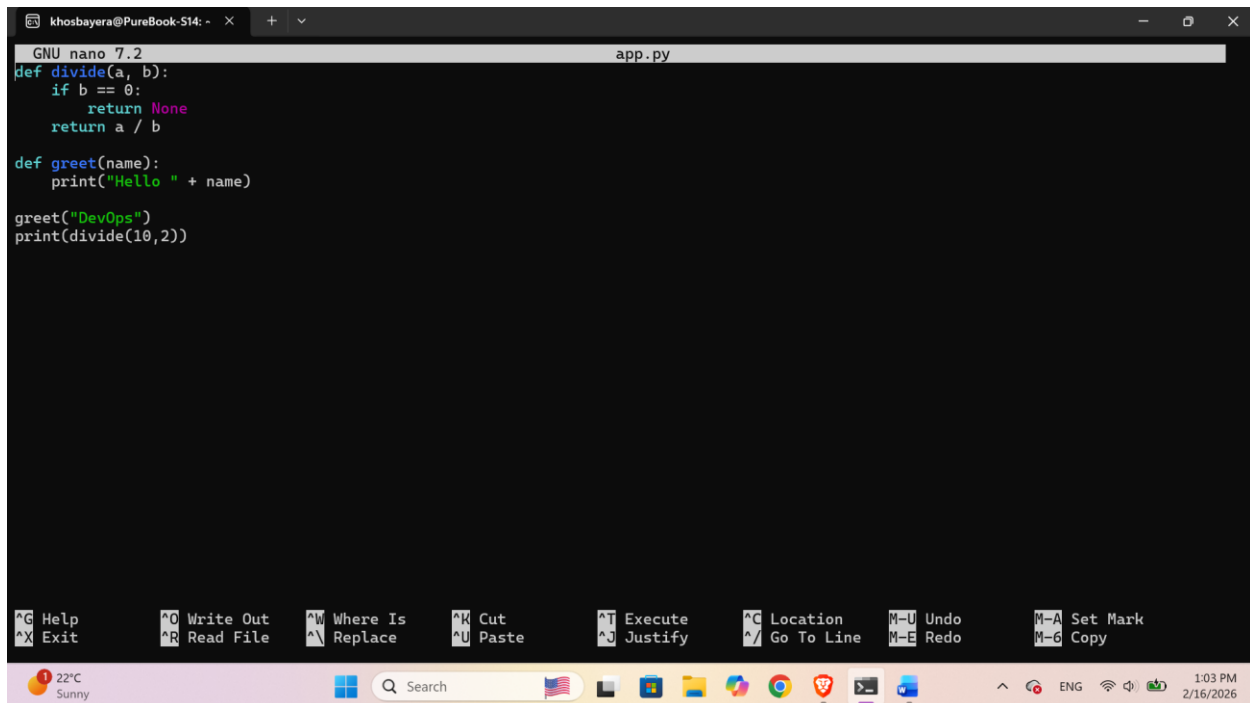
Cloud Quality Gate and Issue Remediation

SonarCloud analysed the project and generated detailed reports including bugs, vulnerabilities, security hotspots, and maintainability issues.

Detected issues were addressed by refactoring code, removing unused variables, and improving code structure. After re-running the pipeline, the Quality Gate successfully met the minimum 80% requirement.



I created app.py and sonar-project.properties files on my virtual machine.



```
GNU nano 7.2 sonar-project.properties *
sonar.projectKey=DevOps
sonar.projectName=DevOps
sonar.sources=
sonar.host.url=http://localhost:9000
sonar.login=squ_58fdb8bfd8396604f7c725ecb572280f01c4f4b0
```

Help Exit Write Out Read File Where Is Replace Cut Paste Read 5 lines Execute Justify Location Go To Line Undo Redo Set Mark Copy

22°C Sunny 1:05 PM 2/16/2026

24Online Client Update SonarCloud action to specific DevOps - Issues - SonarQube Co Overview - devops in KhosbayaBaat

localhost:9000/project/issues?id=DevOps&issueStatuses=OPEN%2CCONFIRMED

Embedded database should be used for evaluation purposes only. It doesn't support scaling, upgrading to a new SonarQube Server version, or migration to another database engine. [Learn more](#)

SonarQube community Projects Issues Rules Quality Profiles Quality Gates Administration More

DevOps Blend project main

Overview Issues Security hotspots Code Measures Activity Project Settings Project Information

My Issues All Bulk Change Select issues Navigate to issue Issues 0 effort

No Issues. Hooray!

Filters

Looking for Bugs, Vulnerabilities, or Code Smells? If your team prefers working with these types, change it in the settings

Issues in new code

Software Quality

Security 0

Reliability 0

Maintainability 0

Severity

Blocker 0

High 0

Medium 0

Low 0

Info 0

Code attribute

Scope

Status

Security Category

SonarQube™ technology is powered by [SonarSource SA](#)

Community Build v25.11.8.114957 - RQR MODE

LGPL v3 Community Documentation Plugins Web API

22°C Sunny 1:06 PM 2/16/2026

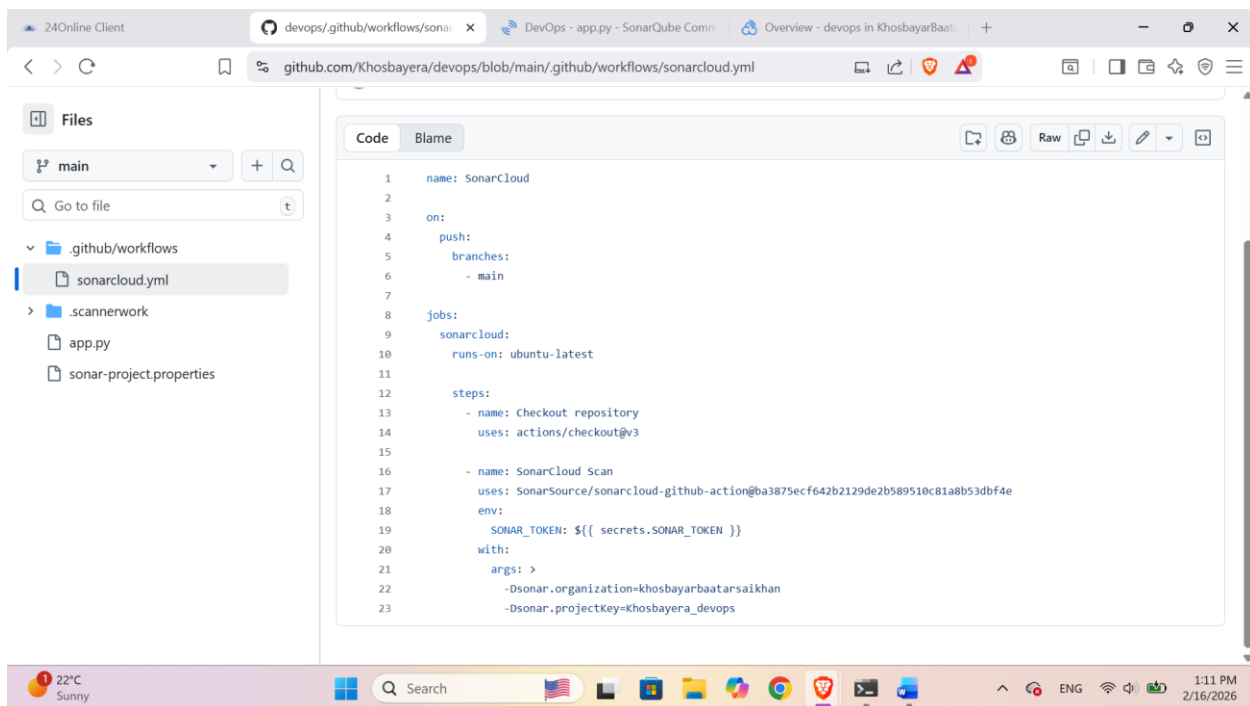
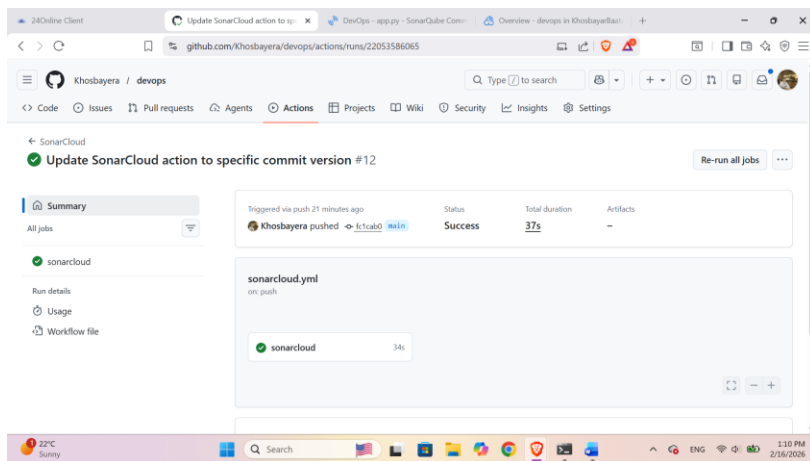
```
DevOps > app.py

DevOps
/app.py

Lines 12 Coverage 0.0% Duplications 0.0% Security 0 Reliability 0 Maintainability 0 Security Hotspot 0

1 def divide(a, b):
2     if b == 0:
3         return None
4     return a / b
5
6 def greet(name):
7     print("Hello " + name)
8
9 greet("DevOps")
10 print(divide(10,2))
11
12
```

GitHub Actions workflow executing automated SonarCloud analysis.



Part 2: Cloud-Based SAST Analysis using SonarCloud

24Online Client x devops/github/workflows/sonarcloud DevOps - app.py - SonarQube Comm Overview - devops in Khosbayera x +

sonarcloud.io/project/overview?id=Khosbayera_devops

SonarQube cloud

My Projects My Issues Explore

devops Project

Public

Overview

Main Branch

Pull Requests

Branches

devops

Quality Gate

Passed

Enjoy your sparkling code!

See Full Analysis

Main Branch Evolution since 1 hour ago

0 Issues 1 New Code

Issues Coverage Duplications

See full history

Latest Activity

NEW ANALYSIS 1 Main Branch

February 16 at 12:48 PM khosbayera Update SonarCloud action to specific commit version

0 Fixed Issues 0 New Issues 0.0% Coverage 0.0% Duplications 0 Lines of Code

Show Older Activity

22°C Sunny

Search

ENG

1:13 PM 2/16/2026

Cloud Quality Gate failed due to detected code issues.

Main Branch February 16 at 12:43 PM  1868132f Update SonarCloud GitHub Action to version 2 0 Fixed Issues 0 New Issues 0.0% Coverage 0.0% Duplications 0 Lines of Code	Failed
Main Branch February 16 at 12:33 PM  facd5e3f Use secret for SONAR_TOKEN in SonarCloud workflow 1 Fixed Issues 0 New Issues 0.0% Coverage 0.0% Duplications 0 Lines of Code	Failed
Main Branch February 16 at 12:19 PM  ee9f8389 Update SonarCloud organization name 0 Fixed Issues 0 New Issues 0.0% Coverage 0.0% Duplications 0 Lines of Code	Failed
Main Branch February 16 at 12:15 PM  ee9f8389 Update SonarCloud organization name 0 Fixed Issues 0 New Issues 0.0% Coverage 0.0% Duplications 0 Lines of Code	Failed This branch has a more recent analysis available. This analysis is outdated. See most recent analysis for this branch
Main Branch February 16 at 12:12 PM  2c44ac84 Update SonarQube project key and organization 0 Fixed Issues 0 New Issues 0.0% Coverage 0.0% Duplications 0 Lines of Code	Failed
Main Branch February 16 at 12:10 PM  17171399 Enhance SonarCloud workflow with checkout step 0 Fixed Issues 0 New Issues 0.0% Coverage 0.0% Duplications +5 Lines of Code	Failed
Main Branch February 16 at 12:08 PM  daa4cb20 Fix formatting of SONAR_TOKEN in sonarcloud.yml 0 Fixed Issues 0 New Issues 0.0% Coverage 0.0% Duplications 0 Lines of Code	Failed
Main Branch	Failed

Conclusion

This assignment demonstrated the practical implementation of Static Application Security Testing using both local and cloud-based tools. By analysing and improving code quality, the project achieved the required Quality Gate threshold in both SonarQube and SonarCloud environments.

The comparison highlighted the advantages of cloud-based automation while also emphasizing the control provided by on-premise deployment. Integrating SAST tools into the development lifecycle enhances software security, maintainability, and reliability.